Ecco un piano operativo prioritario, ordinato, con azioni concrete e stime brevi — esegui in sequenza. Mantieni prima le cose che riducono rischio e abilitano deploy/staging.

Priorità 1 — Stabilità e qualità (immediato)

1. Commit & backup (5–10 min)
   - git add -A && git commit -m "checkpoint"
   - Copy-Item .\prisma\dev.db .\prisma\dev.db.bak -Force Perché: punto di ripristino prima di cambi.
2. CI rapido (30–60 min)
   - Aggiungi workflow GitHub Actions che esegue npm ci, npx prisma generate e npm test su push/PR. Perché: evita regressioni e automatizza i test.
3. Test di integrazione (fatto) — assicurati passano in CI (30–60 min)
   - Verifica che gli integration test (auth, booking, admin) girino in CI; correggi eventuali flakiness. Perché: garanzia base di funzionamento end-to-end.

Priorità 2 — Operatività e sicurezza (1 giorno)
4. Rendere audit robusto/immutabile (1–2 h)

- Conferma che tutte le scritture audit includono req/traceId (hai già corretto i punti principali).
- Disabilita API di update/delete per Audit; lascia solo job amministrativo per retention. Perché: coerenza, tracciatura affidabile.

1. Retention/archiviazione: script + job (4–8 h)
   - Implementa scripts/archive-audits.js (export -> S3/file -> delete) con dry-run.
   - Programma cron o GitHub Actions schedulato. Perché: limita crescita DB e supporta compliance.
2. Mascheramento e GDPR (1–2 h)
   - Verifica maskSensitive su tutti i log; documenta policy (AUDIT_SPEC.md). Perché: privacy/compliance.

Priorità 3 — Observability & performance (1–2 giorni)
7. Indici DB (30–60 min)

- Aggiungi indici su Audit.createdAt, actorHostId, action, entityType via Prisma migrate. Perché: migliora query admin.

1. Metriche & alert (4–8 h)
   - Instrumentare prom-client o inviare metriche a Datadog: failedLogins/min, auditWrites/min, 5xx/min.
   - Configura alert basici (failedLogins spike, DB errors). Perché: rilevamento precoce incidenti.